Information Security Policy

Document ID: POL-SEC-001 | Version: 4.2 | Effective date: 2026-01-15

Owner: Chief Information Security Officer (CISO) | Approved by: Executive Risk Committee

Review cycle: Annual | Classification: Internal

1. Purpose

This policy sets out how Brightwick Retail Group protects the confidentiality, integrity and availability of its information and systems. It applies the same rules to headquarters, stores, distribution centres and remote workers, so that information is protected wherever it is used.

2. Scope

This policy applies to all employees, contractors, agency staff and third parties who access Brightwick information or systems. It covers information in every form, including electronic files, email, printed documents and conversations, and every device used for Brightwick work, whether owned by the company or personally owned and enrolled in Brightwick Mobile.

3. Roles and responsibilities

- The Chief Information Security Officer (CISO) owns this policy, approves exceptions and reports security risk to the Executive Risk Committee.
- The Security Operations Center (SOC) monitors for threats 24 hours a day and leads the response to security incidents.
- Data owners are senior managers who decide the classification of the information their teams create, approve access to it and review that access regularly.
- Line managers make sure their teams complete security training and follow this policy.
- Every user protects the information they handle and reports suspected incidents immediately.

4. Information classification

All Brightwick information must be classified into one of four levels. When information combines several levels, the highest level applies.

Level	Definition	Examples	Key handling rules
Public	Approved for release outside the company	Published prices, press releases, job adverts	No restrictions once approved for release
Internal	For use inside Brightwick; low impact if disclosed	Process documents, internal announcements, IT knowledge articles	Share only with employees and contractors; external sharing needs a business reason
Confidential	Could harm Brightwick, staff or partners if disclosed	Employee records, supplier contracts, unpublished sales figures	Share on a need-to-know basis; manager approval before sharing externally; encrypt when sent outside the company
Restricted	Severe harm if disclosed; often regulated	Customer payment card data, authentication secrets, merger plans	Access only for named people; never on USB drives or personal devices; never sent by email; never shared externally through Brightwick Drive

Information that has not been labelled must be treated as Internal until the data owner decides otherwise.

5. Handling rules

5.1 Storage

Store Brightwick information only in approved company systems: Brightwick Drive, departmental file shares and approved business applications. Restricted information must only be stored in systems that the CISO has approved for Restricted data. Customer payment card data must only exist inside the payment systems and must never be written down, copied into spreadsheets or stored on laptops.

5.2 Email and messaging

Internal and Confidential information may be sent by company email. Confidential information sent outside the company must be encrypted using the "Encrypt" option in the mail client. Restricted information must never be sent by email or chat.

5.3 Printing and paper records

Print Confidential and Restricted information only when there is a clear business need. Collect printouts straight away, store them in locked drawers and dispose of them in the secure shredding bins.

5.4 Disposal of devices

Company devices are disposed of only through IT Asset Management, which wipes the storage to an approved standard or destroys it. Employees must never sell, donate or throw away company devices themselves.

6. Encryption

- All company laptops use full-disk encryption, which IT turns on before the laptop is issued.
- Data sent over networks must use TLS 1.2 or higher.
- Encrypted USB drives are the only removable media allowed, and only with an approved exception.
- Encryption keys for Restricted systems are managed by the Security team and rotated at least once a year.

7. Access management

Access follows the principle of least privilege: each person receives only the access their job needs. Data owners review access to Restricted systems every quarter and to other systems every six months, as set out in the Access Control Policy. Shared accounts are not permitted except where the Access Control Policy allows them.

8. Third parties

Before a supplier or partner is given access to Confidential or Restricted information, the Security team completes a security assessment of that supplier. Contracts with such suppliers must include security and data protection terms. Supplier access is reviewed at least once a year and removed when the contract ends.

9. Security awareness

All employees and contractors complete security awareness training when they join and every year after that. The SOC runs phishing simulations at least once a quarter. People who click repeatedly in simulations are given additional training.

10. Reporting security incidents

Anyone who suspects a security incident must report it immediately, and no later than 1 hour after discovering it. Report incidents by calling the IT Service Desk or by using the Report Phish button for suspicious email. Do not investigate the incident yourself, and do not delete evidence.

11. Exceptions

Where a business need cannot be met within this policy, the requester submits an exception request explaining the risk and the controls that will reduce it. Exceptions must be approved by the CISO, are recorded in the risk

register and last for a maximum of 12 months. Patch exceptions follow the shorter 90-day limit in the Patch Management Standard Operating Procedure.

12. Compliance

Compliance with this policy is checked through audits, monitoring and access reviews. Breaches may lead to disciplinary action, up to and including dismissal, and to the end of contracts for third parties.

13. Related documents

Acceptable Use Policy (POL-SEC-003), Access Control Policy (POL-SEC-002), Patch Management Standard Operating Procedure (OPS-SOP-012), Security Incident Triage Runbook (SEC-RB-002).